MERROWFIELD DIGITAL

Reporting an EU Personal Data Breach

Document Procedure 01 | Rev 4 | Effective 2 February 2026 | Owner: Office of the Data Protection Officer | Review cycle: 12 months

1. Purpose

This procedure sets out how Merrowfield Digital reports personal data breaches affecting customers in the European Union to the lead supervisory authority. The deadlines in section 3 are taken from this document and from no other.

An incident can fall under more than one reporting procedure. When it does, each applicable procedure is followed in full, each deadline is counted from that procedure's own start, and the earliest deadline governs the work (Plan 01, section 8).

2. When this procedure applies

This procedure applies when the personal data of customers in the European Union is involved in an incident - at least one EU data subject - and the harm band is MEDIUM or HIGH.

An incident in band LOW is judged unlikely to result in a risk to the people whose data was involved. It is documented under section 8 and not reported under this procedure. An incident with no EU data subjects is outside this procedure, whatever its band.

3. Deadlines

The deadlines under this procedure are as follows.

The notification to the lead supervisory authority is due within 72 hours of awareness.

Hours are counted continuously, through nights, weekends and public holidays. A deadline is met when the report has been submitted, not when it has been drafted.

4. Where the clock starts

The clock under this procedure starts at awareness: the moment an analyst confirms that the incident is real, recorded on the incident as confirmed_at (Plan 01, section 4).

Until an incident is confirmed, no deadline under this procedure is running. A first alert that is still being triaged is not awareness.

5. What the report contains

The notification to the lead supervisory authority states:

- the nature of the breach, including the categories and approximate number of people and of personal data records concerned
- the name and contact details of the Data Protection Officer
- the likely consequences of the breach for the people concerned
- the measures taken or proposed to address the breach and to reduce its possible adverse effects
- whether, and when, the people concerned have been told

6. Reporting in phases

If the facts a complete report needs are not established by the deadline, an initial report is submitted on time with what is known, and completed as the facts are established. A complete report submitted late is a late report.

The submission is prepared to be sent no later than 30 minutes before the deadline, the filing reserve set in Plan 01.

7. Customers

Customers must be told without undue delay when the harm band is HIGH.

Customers need not be told where the data protection state is Encrypted.

That exemption exists because data encrypted with a key that was not compromised is unintelligible to anyone who takes it. Data that was pseudonymised, hashed and salted, or encrypted with a key that was itself compromised does not qualify: it can still be read, or linked back to a person.

Where telling each customer would involve disproportionate effort, the Data Protection Officer may decide on a public notice instead. Where measures taken after the breach mean the high risk is no longer likely, the Data Protection Officer records why customers were not told.

What a customer notice says, and what it must never say, is set out in Policy 01.

8. Records

Every incident assessed under this procedure is documented - the facts, the decision and the reasons - whether or not a report was submitted. A decision not to report is recorded with its reason, and the record is kept for inspection by the lead supervisory authority.

9. The rule this procedure implements

This procedure is modelled on Articles 33 and 34 of the General Data Protection Regulation. Article 33 requires a personal data breach to be notified to the supervisory authority without undue delay and, where feasible, not later than 72 hours after becoming aware of it, unless the breach is unlikely to result in a risk to people; the information may be provided in phases, and every breach must be documented, whether notified or not.

Article 34 requires the people affected to be told without undue delay when the breach is likely to result in a high risk to them, unless the data was unintelligible to anyone not authorised to see it, such as by encryption; later measures mean the high risk is no longer likely; or telling them individually would involve disproportionate effort, in which case a public communication is made instead.

This procedure is Merrowfield Digital's working instruction. It is not legal advice, and where it and the law differ, the law prevails.